

Before working on this task, read .md to understand the project's history, previous decisions, current state, and important context. After that, investigate this review, if this is true for the project, fix this issue:

st_trancking code review sonucu :🔍 Kritik

1. requirements.txt'ten alembic ve asyncpg düşmüş — Docker deploy çalışmaz ClaudeFixed

backend/requirements.txt bu diff'te pip-freeze çıktısından elle yazılmış listeye geçirilmiş, ama bu sırada üç paket kaybolmuş. Eski dosyada alembic==1.18.5, asyncpg==0.31.0, greenlet==3.5.4 vardı.

docker-compose.yml API servisini sh -c "alembic upgrade head && uvicorn ..." ile başlatıyor → alembic: not found.

DATABASE_URL postgresql+asyncpg:// kullanıyor ama asyncpg kurulu değil → engine oluşturulamaz. Buna karşılık hiç kullanılmayan pycpg2-binary listeye eklenmiş.

Sizin makinenizde çalışıyor olmasının sebebi paketlerin venv'de zaten kurulu olması; temiz bir ortamda proje ayağa kalkmaz.

2. PDF/OCR işlemi event loop'u kilitliyor — backend/app/routers/teacher.py:257 ClaudeFixed

import_classrooms_pdf bir async def ve içinden senkron parse_pdf() çağırılıyor. pdf_roster.py 300 DPI render + Tesseract OCR yapıyor; bu saniyeler-dakikalar süren, tamamen CPU-bound bir iş. Event loop'ta çalıştığı için bir öğretmen PDF yüklerken tüm sunucu yanıt veremez hale gelir (login, yoklama, her şey). Çözüm:

```
from starlette.concurrency import run_in_threadpool
pages = await run_in_threadpool(parse_pdf, file_bytes)
```

Aynı satırda ikinci sorun: await file.read() boyut limiti olmadan tüm dosyayı belleğe alıyor. 500 MB'lık bir "PDF" ile bellek tüketimi mümkün.

3. Varsayılan JWT secret sessizce kabul ediliyor — backend/app/core/config.py:11 ClaudeFixed

.env yoksa uygulama "change-this-to-a-long-random-string" ile açılıyor ve hiç uyarıyor. Bu secret repoda açıkta olduğu için, .env unutulmuş bir kurulumda herkes istediği rolde geçerli token üretebilir. Prod'da fail-fast gerekli:

```
if settings.JWT_SECRET_KEY == "change-this-to-a-long-random-string": raise RuntimeError(...)
```

4. Doğrulama token'ı konsola basılıyor + hata akışı hesabı kilitliyor — ClaudeFixed

backend/app/services/email.py:28,50

print(f"[VERIFICATION EMAIL] ... {link}") her ortamda çalışıyor; SMTP yapılandırılmış olsa bile. Doğrulama linkleri container log'larına düşüyor. Bu if not settings.SMTP_HOST bloğunun içine alınmalı. SMTP hatasında raise ediliyor, ama bu çağrı auth.py:106'daki db.commit()'ten sonra yapılıyor. Sonuç: kullanıcı 500 alır, hesap yine de oluşmuştur, mail gitmemiştir, tekrar kayıt olmaya çalışıldığında "gelen kutunuzu kontrol edin" 409'u alır → hesap kalıcı olarak kilitlenir. raise'i kaldırıp loglamak yeterli (zaten "tekrar gönder" akışı yok, o da ayrı bir eksik).

🔍 Orta

5. FCM gönderimi de bloklayıcı — backend/app/services/push.py:53

messaging.send_each() senkron bir HTTP çağrısı; async def içinde doğrudan çağrılıyor.

BackgroundTask event loop'ta koştuğu için, çok sayıda cihaz token'ı olduğunda duyuru sonrası sunucu kısa süreli donuyor. run_in_threadpool ile sarılmalı.

6. Flutter controller'ları dispose edilmiyor ClaudeFixed

13 TextEditingController var, tüm screens/ altında yalnızca 1 dispose() (o da student_home_screen, stream aboneliği için). login_screen, register_screen (5 adet), teacher_add_grade_screen, teacher_add_classroom_screen, teacher_home_screen:67 (dialog controller'ı) hiçbiri temizlenmiyor. roster_editor.dart ayrıca daha kötü: _removeRow silinen satırın 3 controller'ını bırakıyor ve widget'in hiç dispose'u yok. Sistematik bir bellek sızıntısı.

7. Widget testi kırık — frontend/test/widget_test.dart ClaudeFixed

Test find.text('Log in'), "Don't have an account? Register" gibi İngilizce sabitler arıyor. Ama l10n geçişinde varsayılan dil Türkçe yapıldı (locale_notifier.dart:6 → Locale('tr')), login ekranı artık l10n.logIn render ediyor. Test bu haliyle başarısız olur. Projedeki tek test bu.

8. Çıkışta cihaz token'ı silinmiyor — frontend/lib/services/auth_service.dart:44 ClaudeFixed

logout() sadece session'ı temizliyor; backend'de device_tokens kaydı duruyor ve token'ı silecek bir endpoint de yok. Çıkış yapmış bir öğrencinin telefonu, o öğrencinin sınıflarına gelen duyuru bildirimlerini almaya devam eder. (Ortak cihaz senaryosunu student_home_screen.dart:35'teki force: true kısmen kurtarıyor — yeni öğrenci ana ekrana girince token devralınıyor — ama çıkış ile yeni giriş arasındaki pencere açık kalıyor.) DELETE /student/device-token ekleyip logout'ta çağırmak gerekir.

9. Boşluk (whitespace) doğrulama boşlukları ClaudeFixed

Şemalarda max_length var ama boş-olmama kontrolü sadece RegisterRequest ve RosterStudentIn'de. Sonuç olarak " " gönderildiğinde:

ClassroomCreate.name → teacher.py:69 strip() sonrası isimsiz sınıf oluşuyor

AnnouncementCreate.text → min_length=1 geçiyor, teacher.py:444 strip() ile boş duyuru kaydediliyor (ve boş push bildirimi gidiyor)

GradeCreate.subject / value → boş ders adı / boş not

RegisterRequest.password'de üst sınır yok: bcrypt 72 byte'ı aşan parolada ValueError fırlatır → register 500 döner.

10. Kod deneme / giriş uçlarında rate limit yok ClaudeFixed

/auth/login, /auth/register, /student/teacher-code, /parent/student-code sınırsız denenebiliyor.

Özellikle parent/student-code: doğru kodu bulan herhangi bir veli, herhangi bir öğrencinin notlarına ve duyurularına bağlanabiliyor, öğrenci onayı yok. Kod uzayı (32⁸) brute-force için yeterince geniş ama sınırsız deneme + öğrenci onayının olmaması birleşince zayıf bir kapı. Ayrıca register'daki farklı 409 mesajları e-posta enumeration'a açık.

11. Soft delete tutarsız — backend/app/routers/teacher.py:133-187 ClaudeFixed

delete_classroom sınıfa deleted_at basıyor ama aynı işlemde classroom_students bağlarını kalıcı olarak siliyor ve grades.classroom_id'yi NULL'liyor. Yani "soft" delete geri alınamaz: sınıfı geri getirseniz öğrenci listesi ve notların sınıf bağlantısı yok olmuş olur. Ya gerçek soft delete (bağları koru, sorgularda deleted_at filtrele) ya da düpedüz hard delete — arası kafa karıştırıyor.

12. Eksik indeksler ClaudeFixed

grades.student_id, grades.teacher_id, classroom_students.student_id, teacher_students.student_id indekssiz. Postgres FK'lara otomatik indeks açmaz ve bileşik PK'nın öncü kolonu farklı (classroom_id), dolayısıyla öğrenci tarafındaki tüm sorgular (duyuru listesi, not listesi, push alıcı seçimi) seq scan yapıyor. Veri büyüdükçe hissedilir.

13. Diğer orta seviye notlar ClaudeFixed

main.py:9-15: allow_origins=["*"] + allow_credentials=True varsayılan; prod'da daraltılmalı.

deps.py:29: int(payload["sub"]) — sayısal olmayan sub'da ValueError → 401 yerine 500.

teacher.py:328,551: classroom_id query parametresi sahiplik doğrulaması yapmıyor (veri sızıntısı yok, sonuçlar zaten teacher_id ile sınırlı; yine de tutarsızlık — _get_owned_classroom burada da kullanılmalı).

roster.py:24: _generate_student_code öğrenci başına ayrı SELECT; 30 kişilik PDF importunda 30+ gereksiz sorgu.

docker-compose.yml: Postgres 5432 host'a açık ve parola changeme.

🔍 Düşük / temizlik ClaudeFixed

frontend/lib/services/fcm_service.dart:80-85 — dosyanın sonunda ölü kod: ikinci bir _firebaseMessagingBackgroundHandler, private ve hiçbir yere kayıtlı değil (gerçek olan main.dart:33'te). Üstündeki "DİKKAT: ... top-level tanımlanmalıdır" yorumu da yanıltıcı. Silinmeli.

Aynı dosyada print() (2 yer) — flutter_lints'in avoid_print kuralını ihlal ediyor; debugPrint olmalı.
Ayrıca kod tabanının geri kalanı İngilizce yorumluyken burada Türkçe yorumlar var.
student_home_screen.dart:131 — snapshot.error as ApiException? cast'i; hata ApiException değilse (ör. FormatException) build içinde TypeError fırlar. is kontrolü daha güvenli.
student_home_screen.dart:46 — _loadTeachers() try/catch'siz ve await edilmeden çağrılıyor; API hatası unhandled async error olur.
api_client.dart — hiçbir istekte timeout yok; ayrıca jsonDecode JSON olmayan gövdede (proxy'den gelen HTML 502 gibi) ApiException yerine FormatException fırlatır.
~~config.dart:11 — doküman yorumunun içinde artık kalmış LAN IP: //http://172.16.0.46:8000.~~
Dropdown'larda value: (2 yer) / initialValue: (4 yer) karışık kullanılıyor; value yeni Flutter'da deprecated.
pagination.py:19 — total=0 iken total_pages 1 dönüyor; UI "Sayfa 1/1" gösteriyor, kasıtlıysa sorun değil ama total_pages=0 daha doğru bir sözleşme.
teacher_service.dart:26,86 — listAllClassrooms/listAllStudents tüm sayfaları paralel çekiyor; backend'de sayfasız bir "hepsi" ucu olsa tek istek yeterdi.